

Data Retention and PII Encryption Standards

Author: Security Architecture Board	Target Audience: Core Engineers / Dev Leads	Compliance Target: PCI-DSS v4.0, GDPR
--	--	--

1.0 Purpose & Strategic Context

Unsecured Personally Identifiable Information (PII) and raw financial credentials represent the single largest regulatory liability a company can possess during an exit transaction. This document establishes absolute cryptography mandates to eliminate security exposure, ensure strict compliance with international standards, and prevent material valuation write-downs during legal due diligence.

2.0 Cryptographic Protocol Mandates

Section 3.1 Encryption-at-Rest Standards

All production data stores capturing user identification parameters, bank accounts, primary account numbers (PAN), or corporate ledger entries must utilize industry-standard, authenticated symmetric encryption. The mandatory core primitive is **AES-256** deployed in Galois/Counter Mode (GCM).

Section 3.2 Absolute Prohibition of Hardcoded Key Materials

Under no circumstances may symmetric keys, authorization block parameters, salts, or fallback secrets be stored as string literal constants within source files, compiled assemblies, or local app configuration manifests. All keys must be loaded dynamically at engine initialization via authenticated integrations with enterprise key management solutions (e.g., Azure Key Vault, AWS KMS, HashiCorp Vault).

Section 3.4 Decommissioning of Legacy Primitives

The use of historical or broken encryption algorithms—specifically including **TripleDES (3DES)**, **DES**, **Blowfish**, and **MD5** for validation—is strictly banned across all production systems. Any application utilizing these deprecated models fails technical audit thresholds immediately and requires immediate code refactoring.

CRITICAL AUDIT FAILURE EXPOSURE: Legacy systems utilizing ECB (Electronic Codebook) modes or hardcoded string fallbacks allow structural data patterns to remain visible in ciphertext. This constitutes an automatic non-compliance mark, voiding transaction warranties and risking immediate merchant processor suspension.

